

PES UNIVERSITY, BENGALURU

Department of Computer Science and Engineering

Software Requirements Specification

Online Bookstore

Version 1.1 – Final

Team 2

Prepared by:

M1 – PES1UG24CS323 – Pooja Avadhani

M2 – PES1UG24CS359 – Rahul M S

M3 – PES1UG24CS342 – Preksha B

M4 – PES1UG24CS307 – Ojas Binjola

Organization: PES University

Date Created: October 2026

Prepared in accordance with the structure of IEEE Std 830-1998

Revision History

Name	Date	Reason for Changes	Version
M1	October 2026	Initial draft of the Software Requirements Specification.	1.0
M1 (with M2, M3, M4)	October 2026	Synchronized with SAD v1.1, Software Test Plan and the Security & Integration Plan: security objectives and detailed security controls added; use-case diagram added; logout (FR-AUTH-03) and view cart (FR-CART-03) added; open decisions resolved (Appendix D); requirements made measurable; Seller ownership of listings, Order Item and order status added to the data requirements; traceability matrix completed.	1.1 (draft)
M1 (with M2, M3, M4)	October 2026	Final consistency pass across SRS, SAD, STP and Security & Integration Plan: status changed to Final; SEC-CTRL-16 reworded as an optional recommended enhancement outside the mandatory acceptance baseline; Appendix D location reference for the database decision corrected. No functional, non-functional or security requirement was changed.	1.1 (Final)

Contents

1	Introduction	4
1.1	Purpose	4
1.2	Scope	4
1.3	Definitions, Acronyms, and Abbreviations	4
1.4	References	5
1.5	Overview	6
2	Overall Description	6
2.1	Product Perspective	6
2.2	Product Functions	6
2.3	User Characteristics	7
2.4	Constraints	7
2.5	Assumptions and Dependencies	7
3	Specific Requirements	8
3.1	External Interface Requirements	8
3.1.1	User Interfaces	8
3.1.2	Software Interfaces	8
3.1.3	Communications Interfaces	8
3.1.4	Analysis Models	8
3.2	Functional Requirements	8
3.2.1	User Authentication	10
3.2.2	Book Management	11
3.2.3	Shopping Cart Management	11
3.2.4	Order Management	12
3.3	Non-Functional Requirements	13
3.3.1	NFR-01 – Performance	13
3.3.2	NFR-02 – Usability	13
3.3.3	NFR-03 – Reliability	13
3.3.4	NFR-04 – Availability	13
3.3.5	NFR-05 – Compatibility	13
3.3.6	NFR-06 – Maintainability	13
3.3.7	NFR-07 – Testability	13
3.4	Design Constraints	13

3.5	Security Requirements	14
3.5.1	Security Objectives	14
3.5.2	SEC-01 – Role-Based Access	14
3.5.3	SEC-02 – Protection of User Data	14
3.5.4	Detailed Security Controls	14
3.5.5	RBAC Matrix	16
3.6	Software Quality Attributes	16
3.7	Business Rules	17
3.8	Other Requirements	17
3.8.1	Database Requirements	17
3.8.2	Technology Requirement	17
3.8.3	Error Handling and Logging	17
A	Glossary	18
B	Field Layouts	18
B.1	User Registration	18
B.2	Book Listing	19
B.3	Shopping Cart	19
B.4	Order	19
B.5	Order Item	19
C	Requirement Traceability Matrix	20
C.1	Requirements to Design and Tests	20
C.2	Security Controls	21
D	Decisions Resolved in Version 1.1 and Remaining Open Items	21

1 Introduction

1.1 Purpose

This Software Requirements Specification (SRS) defines the requirements for the Online Bookstore system, Version 1.1. It specifies the functional, non-functional, security, interface and other requirements of the system. The intended readers are the project team (requirements, design, test and integration members), the project guide and the reviewers.

The assigned problem statement for Team 2 is: “Online Bookstore – an e-commerce platform for buying and selling books online”. The team has selected the Python (Django) option offered in the problem statement.

The system provides a web-based platform through which customers can browse and search for books, manage a shopping cart, place orders and view their order history, and through which sellers can add book listings.

This SRS is the authoritative requirements baseline for the Software Architecture and Design Specification (SAD), the Software Test Plan (STP), the Security & Integration Plan and the implementation.

1.2 Scope

The software product is named *Online Bookstore*. It is a web-based e-commerce application for buying and selling books online.

In scope:

- User registration, login and logout.
- Browsing and searching books.
- Adding book listings by sellers.
- Adding books to, removing books from, and viewing a shopping cart.
- Placing orders and viewing order history.
- Role-based access control and protection of user data.

Out of scope (unless later approved and added to this SRS): payment processing, shipping and delivery tracking, reviews and ratings, recommendations, wishlists, discounts, inventory replenishment, seller payouts, editing or deleting listings, administrator dashboards, and mobile applications.

The system supports two registered user roles:

- **Customer** – a registered user who browses and purchases books.
- **Seller** – a registered user who adds book listings.

Unregistered visitors (Anonymous Visitor) may register, log in, browse and search.

1.3 Definitions, Acronyms, and Abbreviations

Term	Definition
SRS	Software Requirements Specification
SAD	Software Architecture and Design Specification
STP	Software Test Plan
FR	Functional Requirement
NFR	Non-Functional Requirement
SEC	Security Requirement
SEC-CTRL	Detailed security control that supports SEC-01 or SEC-02
SO	Security Objective
BR	Business Rule
UI	User Interface
API	Application Programming Interface
RBAC	Role-Based Access Control
CSRF	Cross-Site Request Forgery
XSS	Cross-Site Scripting
IDOR	Insecure Direct Object Reference
Anonymous Visitor	A user who is not logged in
Customer	Registered user who purchases books through the platform
Seller	Registered user who can add book listings
Book Listing	Information representing a book available on the platform
Cart	Collection of books and quantities selected by a Customer for purchase
Order	Record of books purchased by a Customer, created from the cart
Order Item	A line of an Order containing a book, quantity and purchase-time unit price
Authentication	Process of verifying the identity of a user
Authorization	Process of determining whether a user is allowed to perform an operation
Django	Python-based web framework used to develop the Online Bookstore
ORM	Object-Relational Mapping

1.4 References

1. IEEE Std 830-1998, *IEEE Recommended Practice for Software Requirements Specifications*.
2. PES University, Department of Computer Science and Engineering, Software Requirements Specification Template.
3. PES University, Department of Computer Science and Engineering, Online Bookstore Mini-Project Guidelines.
4. Online Bookstore Software Architecture and Design Specification, Version 1.1, October 2026.

5. Online Bookstore Software Test Plan, Version 1.1, October 2026.
6. Online Bookstore – Security & Integration Plan (M4), Version 1.1, October 2026.

1.5 Overview

- Section 1 – Introduction: purpose, scope, terminology, references and organization.
- Section 2 – Overall Description: product perspective, functions, user characteristics, constraints, assumptions and dependencies.
- Section 3 – Specific Requirements: external interfaces and analysis models, functional requirements, non-functional requirements, design constraints, security objectives and requirements, quality attributes, business rules and other requirements.
- Appendix A – Glossary.
- Appendix B – Field Layouts.
- Appendix C – Requirement Traceability Matrix.
- Appendix D – Decisions Resolved in Version 1.1 and Remaining Open Items.

2 Overall Description

2.1 Product Perspective

The Online Bookstore is a new, self-contained, web-based application. It runs in a web browser and is served by a Django application backed by a relational database.

The architecture is a layered modular monolith (see SAD Section 3.5). The major logical components and their Django modules are:

- Accounts / Authentication (**accounts**) – registration, login, logout, sessions, roles.
- Book Management (**books**) – browsing, searching and seller listing creation.
- Cart Management (**cart**) – add, remove and view cart items.
- Order Management (**orders**) – order placement and order history.
- Django Models and ORM, and the Relational Database.

Operating environment: the latest stable versions of Google Chrome, Mozilla Firefox and Microsoft Edge on a desktop or laptop computer. The database is SQLite for development and demonstration, and PostgreSQL if the system is hosted. The deployment environment will be finalized by the team (Appendix D).

2.2 Product Functions

User Authentication: register a new user as a Customer or Seller; authenticate registered users (login); end a user session (logout).

Book Management: browse available books; search for books; allow sellers to add book listings.

Shopping Cart Management: add books to the cart, remove books from the cart, and view the cart.

Order Management: place an order and view previously placed orders.

Security: enforce role-based access and protect user data.

2.3 User Characteristics

The system has three kinds of users. Role names are written exactly as Anonymous Visitor, Customer and Seller in all project documents.

Anonymous Visitor is a user who is not logged in. An Anonymous Visitor shall be able to register, log in, browse books and search for books.

Customer is a registered user who uses the platform to browse and purchase books. A Customer shall be able to log in and log out, browse and search books, add books to the cart, remove books from the cart, view the cart, place orders and view their own order history.

Seller is a registered user who adds book listings. A Seller shall be able to log in and log out, browse and search books, and add book listings. A Seller shall not perform customer purchasing operations (BR-03).

Role-Based Access. The system shall restrict protected functionality according to the user's assigned role (Section 3.5). A Django superuser, created only through the `createsuperuser` management command for system maintenance, is not a user role of this system.

2.4 Constraints

- The application shall be implemented using the Python Django web framework.
- The system shall operate as a web-based application.
- The system shall use a relational database for persistent data (SQLite for development and demonstration; PostgreSQL if hosted).
- User access shall be controlled according to assigned roles.
- User data shall be protected from unauthorized access and disclosure.
- The implementation shall remain consistent with this SRS.
- Functional and non-functional requirements shall be testable.

2.5 Assumptions and Dependencies

Assumptions

- Users have a compatible web browser and network connectivity.
- Users provide valid information during registration, and Sellers provide valid information when adding listings.
- Payment is not part of this version; placing an order only records the order.

Dependencies

- The system depends on the Django framework and on a relational database for user, book, cart and order data.
- The system depends on network connectivity for client–server communication.
- The system depends on the selected deployment environment for hosting.

3 Specific Requirements

3.1 External Interface Requirements

The system has no dedicated hardware interfaces; it is used from a standard desktop or laptop computer through a web browser.

3.1.1 User Interfaces

The system shall provide web-based interfaces for user registration, login, logout, book browsing, book search, seller book addition, shopping cart management and viewing, order placement and order history. The interface shall provide clear navigation and a visible success or error message after every operation (NFR-02).

3.1.2 Software Interfaces

The system shall interact with the following software components: a web browser, the Django application, a relational database management system (SQLite for development and demonstration; PostgreSQL if hosted) and the Django ORM.

3.1.3 Communications Interfaces

The client and the Django application shall communicate over HTTP/HTTPS. HTTPS shall be used in any hosted environment (SEC-CTRL-17); plain HTTP is permitted only on a local development machine. State-changing requests shall use HTTP POST with CSRF tokens (SEC-CTRL-12).

3.1.4 Analysis Models

UML Use Case Diagram. Figure 1 shows the use cases of the Online Bookstore. Table 3 maps every use case to its functional requirement.

Entity-Relationship Diagram. Figure 2 shows the logical data model. The detailed field layouts are in Appendix B and the model is detailed in SAD Section 3.6.

3.2 Functional Requirements

The functional requirements are organized by major feature. In this SRS the term “authenticated” means logged in with a valid session.

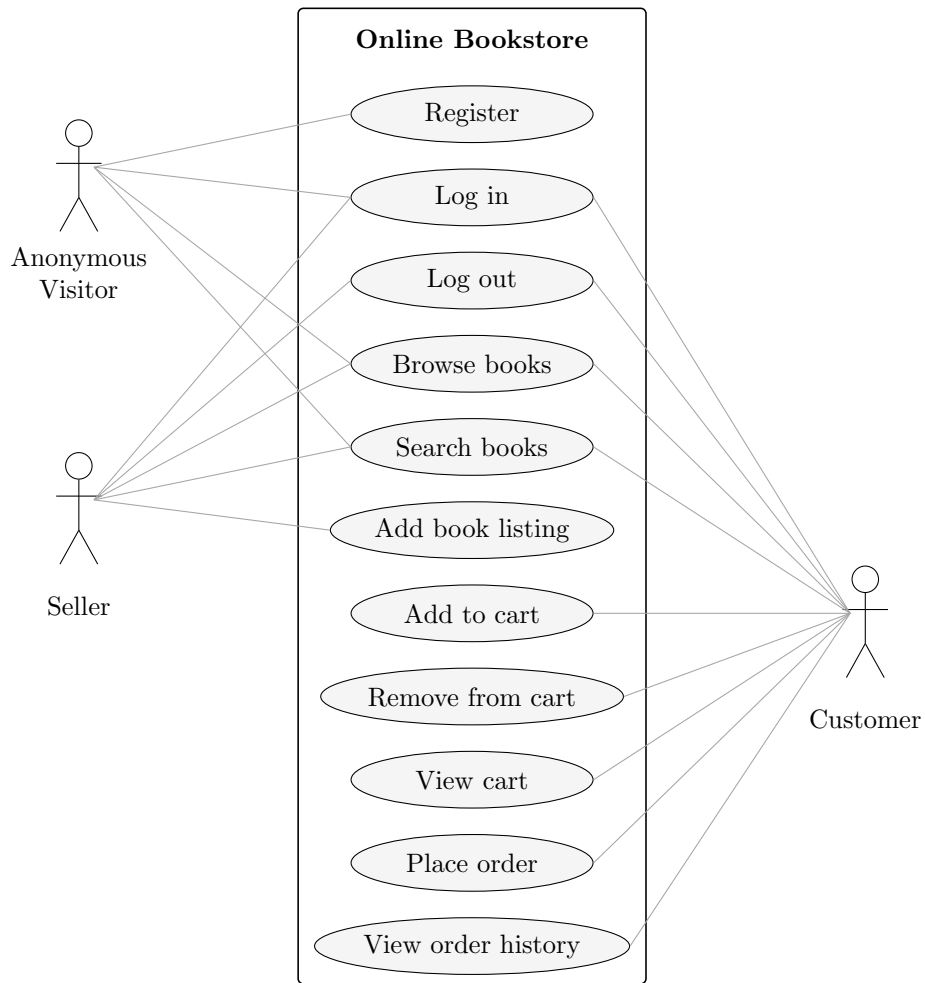


Figure 1: Online Bookstore Use Case Diagram

Use case	Actors	Requirement
Register	Anonymous Visitor	FR-AUTH-01
Log in	Anonymous Visitor, Customer, Seller	FR-AUTH-02
Log out	Customer, Seller	FR-AUTH-03
Browse books	Anonymous Visitor, Customer, Seller	FR-BOOK-01
Search books	Anonymous Visitor, Customer, Seller	FR-BOOK-02
Add book listing	Seller	FR-BOOK-03
Add to cart	Customer	FR-CART-01
Remove from cart	Customer	FR-CART-02
View cart	Customer	FR-CART-03
Place order	Customer	FR-ORDER-01
View order history	Customer	FR-ORDER-02

Table 3: Use case to requirement mapping

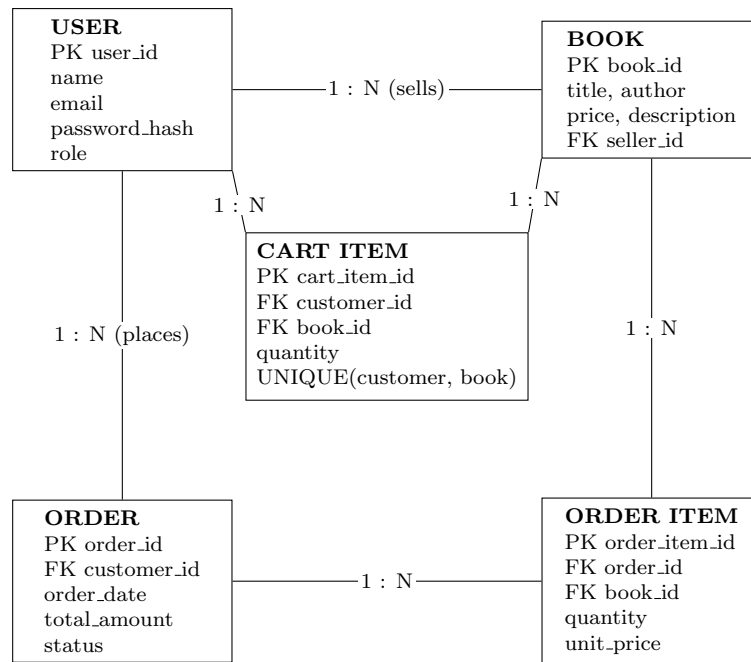


Figure 2: Logical data model (Entity-Relationship Diagram)

3.2.1 User Authentication

Description and Priority. Registration, login and logout for users. Priority: High.

Stimulus/Response Sequences

1. The user selects the registration option; the system displays the registration form.
2. The user submits the required information; the system validates it and creates the account when it is valid.
3. The user submits login credentials; the system validates them and grants access when they are valid.
4. The logged-in user selects logout; the system ends the session.

FR-AUTH-01: The system shall allow an Anonymous Visitor to register for an account by providing Name, Email, Password and Role (Customer or Seller).

- (a) The system shall reject the registration, create no account and show field-level errors if any mandatory field is missing, the email format is invalid, the email is already registered, or the password does not satisfy SEC-CTRL-02.
- (b) The Role shall be chosen only from the allowed values Customer and Seller and validated by the server (SEC-CTRL-07).
- (c) The password shall be stored only as a salted hash (SEC-CTRL-01).

FR-AUTH-02: The system shall allow a registered user to log in using the registered Email and Password.

- (a) On valid credentials the system shall create a new session and redirect the user to the home page, or to a validated return address (SEC-CTRL-20).
- (b) On invalid credentials the system shall display one generic failure message that does not

reveal whether the email exists (SEC-CTRL-03).

FR-AUTH-03: The system shall allow an authenticated user to log out. On logout the system shall destroy the current session; a request that reuses the old session shall be treated as made by an Anonymous Visitor (SEC-CTRL-04).

3.2.2 Book Management

Description and Priority. Browsing and searching of books by all users, and addition of book listings by authenticated Sellers. Priority: High.

Stimulus/Response Sequences

1. The user opens the book section; the system displays the available books.
2. The user enters search text; the system displays the matching books.
3. An authenticated Seller selects the add-book option and enters the book information; the system validates and stores the listing.

FR-BOOK-01: The system shall allow Anonymous Visitors, Customers and Sellers to browse the available books. Each book shall be displayed with its title, author, price and, where available, description. Results shall be paginated (SEC-CTRL-15).

FR-BOOK-02: The system shall allow Anonymous Visitors, Customers and Sellers to search for books by title or author using case-insensitive partial matching.

- (a) The search text shall not exceed 100 characters and results shall be paginated at 20 books per page (SEC-CTRL-15).
- (b) If no book matches, the system shall display a “no results” message.

FR-BOOK-03: The system shall allow an authenticated Seller to add a book listing by providing Title, Author and Price (mandatory) and Description (optional).

- (a) The Price shall be a positive number with at most two decimal places.
- (b) The system shall record the Seller who created the listing.
- (c) A request from an Anonymous Visitor shall be redirected to login, and a request from a Customer shall be denied with HTTP 403, in both cases without creating a listing.

3.2.3 Shopping Cart Management

Description and Priority. Management and viewing of books selected for purchase by authenticated Customers. Priority: High.

Stimulus/Response Sequences

1. The Customer selects a book and the add-to-cart option; the system adds the book to the Customer’s cart.
2. The Customer opens the cart; the system displays the cart contents.
3. The Customer selects the remove option for a cart item; the system removes it.

FR-CART-01: The system shall allow an authenticated Customer to add an existing book to the shopping cart with a quantity (default 1).

- (a) If the book is already in the cart, the system shall increase the quantity of the existing line; the cart shall contain at most one line per book per Customer.
- (b) The quantity of a cart line shall be a positive integer not exceeding 10 (SEC-CTRL-10); otherwise the cart shall remain unchanged and an error shall be shown.
- (c) The cart shall not store a price; prices are read from the stored book record.

FR-CART-02: The system shall allow an authenticated Customer to remove a book from their own shopping cart. A request to remove an item that does not belong to the Customer shall return HTTP 404 and change no data (SEC-CTRL-08).

FR-CART-03: The system shall allow an authenticated Customer to view their own cart, showing for each line the book title, quantity, current unit price and line total, together with the cart total. If the cart is empty the system shall display an empty-cart message.

3.2.4 Order Management

Description and Priority. Placing of orders and viewing of order history by authenticated Customers. Priority: High.

Stimulus/Response Sequences

1. The Customer selects place order; the system validates the cart.
2. The system creates the order, clears the cart and displays a confirmation.
3. The Customer opens order history; the system displays the Customer's orders.

FR-ORDER-01: The system shall allow an authenticated Customer to place an order containing the books in their shopping cart.

- (a) If the cart is empty, no order shall be created and an explanatory message shall be shown.
- (b) The system shall compute the order total from the current stored book prices and shall ignore any price or total submitted by the client (SEC-CTRL-09).
- (c) The system shall create the Order with status "Placed" and one Order Item per cart line, each recording the book, quantity and purchase-time unit price.
- (d) The Order, its Order Items and the clearing of the cart shall complete as one all-or-nothing operation (SEC-CTRL-11). On failure, no Order or Order Item shall exist and the cart shall remain unchanged.
- (e) On success the system shall display a confirmation showing the order identifier and total.
- (f) Placing an order does not involve payment processing.

FR-ORDER-02: The system shall allow an authenticated Customer to view their own previously placed orders, showing for each order the order identifier, date and time, status, total and items, most recent first. The system shall never display another Customer's orders (SEC-CTRL-08). If there are no orders, an empty-history message shall be shown.

3.3 Non-Functional Requirements

3.3.1 NFR-01 – Performance

The system shall display book search results within 3 seconds under normal operating conditions, defined as a catalogue of up to 10,000 book listings and up to 50 concurrent users in the agreed test environment.

3.3.2 NFR-02 – Usability

The system shall allow a user to complete the major operations – login, book search, cart operation and order placement – through clear and consistent navigation. Each major operation shall be reachable within three clicks from the home page, and every operation shall end with a visible success or error message.

3.3.3 NFR-03 – Reliability

The system shall maintain cart and order data consistency after every completed operation. A forced failure during order creation shall leave no partial Order or Order Item and shall leave the cart intact.

3.3.4 NFR-04 – Availability

The system shall be available for normal operations for at least 99% of scheduled operating time, excluding planned maintenance, measured over an agreed monitoring period.

3.3.5 NFR-05 – Compatibility

The system shall support the latest stable versions of Google Chrome, Mozilla Firefox and Microsoft Edge available at the time of testing.

3.3.6 NFR-06 – Maintainability

The system shall use modular software components (accounts, books, cart, orders) so that a change to one major functional area does not require modification of unrelated areas. Only the accounts module shall implement role checks; other modules shall use it.

3.3.7 NFR-07 – Testability

Each functional requirement and security requirement shall be independently testable and shall be covered by at least one test case in the Software Test Plan.

3.4 Design Constraints

- The application shall be implemented using Python Django as a web-based application.
- The system shall use a relational database accessed only through the Django ORM (SEC-CTRL-14).

- The system shall enforce role-based access on the server and protect user data from unauthorized access.
- The system shall maintain modularity between the major functional components (NFR-06).

3.5 Security Requirements

3.5.1 Security Objectives

ID	Objective	Meaning for this system
SO-1	Confidentiality	A user can see only their own cart, orders and account data. Passwords are never stored in recoverable form.
SO-2	Integrity	Prices, totals, roles, ownership and order state are decided by the server and never trusted from the client. Orders are all-or-nothing.
SO-3	Availability	Misuse such as expensive search requests shall not take the site down; supports the 99% target of NFR-04.
SO-4	Authenticity	Every protected action is tied to a verified, logged-in identity.
SO-5	Authorization	Customers and Sellers can perform only the operations permitted for their role, enforced on the server.
SO-6	Accountability	Failed logins, denied access and failed orders are logged, without secrets, so incidents can be investigated.

3.5.2 SEC-01 – Role-Based Access

The system shall enforce role-based access on the server so that users can access only the functions permitted for their assigned role, as defined in the RBAC matrix of Section 3.5.5. A request by a user whose role does not permit the operation shall be denied and shall change no data. Priority: High.

3.5.3 SEC-02 – Protection of User Data

The system shall protect user data from unauthorized access and disclosure, using the detailed controls of Section 3.5.4. Priority: High.

3.5.4 Detailed Security Controls

The controls below refine SEC-01 and SEC-02. Their identifiers are used unchanged in the SAD (Section 3.10.2), the STP (Section 16.2) and the Security & Integration Plan. SEC-CTRL-01 to SEC-CTRL-15 and SEC-CTRL-17 to SEC-CTRL-20 are mandatory. SEC-CTRL-16 is a recommended enhancement: it is optional for the current implementation and is not part of the mandatory acceptance baseline.

ID	Requirement	Obj.	Parent
SEC-CTRL-01	Passwords shall be stored only as salted hashes using Django's password hasher.	SO-1	SEC-02
SEC-CTRL-02	Password validators shall be enabled: minimum length of 8 characters, not a commonly used password, not entirely numeric.	SO-4	SEC-02
SEC-CTRL-03	Login failures shall show one generic message that does not reveal whether the email exists.	SO-1	SEC-02
SEC-CTRL-04	A session shall be created only after valid credentials, regenerated at login and destroyed at logout; an old session shall be invalid after logout.	SO-4	SEC-02
SEC-CTRL-05	Every protected route shall require authentication; anonymous users shall be redirected to login.	SO-4	SEC-01
SEC-CTRL-06	Every protected route shall enforce the user's role on the server; a wrong role shall receive HTTP 403 with no data change.	SO-5	SEC-01
SEC-CTRL-07	The role shall be stored server-side and chosen only from the allowed set (Customer, Seller). It shall never be taken from a hidden field or URL, and no form shall allow a user to become staff or administrator.	SO-5	SEC-01
SEC-CTRL-08	Cart and order queries shall be scoped to the logged-in user; client-supplied customer identifiers shall be ignored, and another user's object shall return HTTP 404.	SO-1	SEC-02
SEC-CTRL-09	Prices and totals shall be computed on the server from stored book records; client-submitted prices shall be ignored.	SO-2	SEC-02
SEC-CTRL-10	Quantities shall be validated as positive integers not exceeding 10 per cart line.	SO-2	SEC-02
SEC-CTRL-11	Order creation (Order, Order Items and cart clearing) shall run in one database transaction.	SO-2	SEC-02
SEC-CTRL-12	All state-changing requests shall use POST with a valid CSRF token.	SO-2	SEC-02
SEC-CTRL-13	User-supplied content (book title, description, search text) shall be output-escaped; raw HTML rendering is not allowed.	SO-2	SEC-02
SEC-CTRL-14	Database access shall use the Django ORM only, with no SQL built from user input.	SO-2	SEC-02
SEC-CTRL-15	Search input shall be limited to 100 characters and results shall be paginated at 20 per page.	SO-3	SEC-02
SEC-CTRL-16	Recommended enhancement (optional). Repeated failed logins (for example 5 consecutive attempts) may be throttled or cause a temporary logout. Not part of the mandatory acceptance baseline.	SO-3, SO-4	SEC-02

ID	Requirement	Obj.	Parent
SEC-CTRL-17	In a hosted environment: DEBUG=False, HTTPS, secure and HttpOnly cookies, HSTS, and secrets read from environment variables, not from source code.	SO-1	SEC-02
SEC-CTRL-18	Logs shall never contain passwords, session identifiers, secret keys or tokens. Failed login, denied access and failed order events shall be logged with user identifier and timestamp.	SO-6	SEC-02
SEC-CTRL-19	Users shall see generic error pages; stack traces shall never be exposed.	SO-1	SEC-02
SEC-CTRL-20	The post-login return (next) address shall be validated against the application host; external addresses shall be ignored.	SO-4	SEC-02

3.5.5 RBAC Matrix

This matrix is the single source of truth for role behaviour. Routes are indicative; the tests verify behaviour, not exact URL names.

Operation (route)	Anonymous Visitor	Customer	Seller
Register / Login / Logout	Allowed	Allowed	Allowed
Browse / Search (/books/, /books/search/)	Allowed	Allowed	Allowed
Add listing (/books/add/)	Login required	403 Denied	Allowed
View cart (/cart/)	Login required	Own cart only	403 Denied
Add / remove cart item	Login required	Own cart only	403 Denied
Place order (/orders/place/)	Login required	Own cart only	403 Denied
View order history (/orders/)	Login required	Own orders only	403 Denied

3.6 Software Quality Attributes

Attribute	Req.	Description
Performance	NFR-01	Search results within 3 seconds under normal operating conditions.
Usability	NFR-02	Major operations reachable through clear, consistent navigation.
Reliability	NFR-03	Cart and order data remain consistent after completed operations.
Availability	NFR-04	At least 99% scheduled availability, excluding planned maintenance.

Attribute	Req.	Description
Compatibility	NFR-05	Latest stable Chrome, Firefox and Edge.
Maintainability	NFR-06	Modular components with clear boundaries.
Testability	NFR-07	Every requirement independently testable.
Security	SEC-01, SEC-02	Role-based access and protection of user data.

3.7 Business Rules

- **BR-01:** A user shall register before using functions that require an authenticated account.
- **BR-02:** Only an authenticated Seller shall add book listings.
- **BR-03:** Only an authenticated Customer shall perform cart and order operations. A Seller cannot purchase books in this version.
- **BR-04:** Each account has exactly one role, chosen at registration; a user cannot change it afterwards.
- **BR-05:** Access restrictions shall be applied consistently to all protected functions.
- **BR-06:** Prices are always read from the stored book record. The unit price of an Order Item is copied at the time of purchase, so a later price change does not alter existing orders.
- **BR-07:** Placing an order only records the order; no payment is processed.
- **BR-08:** Adding a book already in the cart increases the quantity of the existing cart line.

3.8 Other Requirements

3.8.1 Database Requirements

The system shall maintain persistent data for user accounts, user roles, book listings (including the creating Seller), cart items, orders and order items. The database shall enforce foreign keys, mandatory fields, a quantity greater than zero, and uniqueness of (Customer, Book) in the cart. The final schema is specified in SAD Section 3.6.

3.8.2 Technology Requirement

The Online Bookstore shall be implemented using the Python Django web framework, which shall be used for web application development, application logic, user authentication, role and permission management, and database interaction through the Django ORM. Django templates, HTML and CSS shall be used for the user interface.

3.8.3 Error Handling and Logging

The system shall show field-level validation errors without exposing internal details, shall show generic error pages for unexpected failures (SEC-CTRL-19), and shall log failed login, denied access and failed order events without sensitive values (SEC-CTRL-18).

A Glossary

Term	Meaning
Anonymous Visitor	A user who is not logged in.
Customer	A registered user who browses and purchases books.
Seller	A registered user who adds book listings.
Book Listing	Information representing a book available on the platform.
Cart	A collection of books and quantities selected by a Customer for purchase.
Order	A record of a Customer's purchase, created from the cart.
Order Item	A line of an Order: book, quantity and purchase-time unit price.
Authentication	The process of verifying a user's identity.
Authorization	The process of determining whether a user may perform an operation.
Role	A category assigned to a user that determines permitted operations.
RBAC	Role-Based Access Control.
CSRF	Cross-Site Request Forgery, an attack that submits unwanted requests using a victim's session.
XSS	Cross-Site Scripting, injection of script into pages shown to other users.
IDOR	Insecure Direct Object Reference, access to another user's object by changing an identifier.
Django	A Python web framework used to implement the Online Bookstore.
ORM	Object-Relational Mapping between application objects and database data.

B Field Layouts

Final field definitions are synchronized with the database design in the SAD (Section 3.6).

B.1 User Registration

Field	Data Type	Mandatory	Description
Name	String	Yes	Name of the user.
Email	String	Yes	Unique email address; used as the login identifier.
Password	String	Yes	Credential; stored only as a salted hash.

Field	Data Type	Mandatory	Description
Role	String	Yes	Customer or Seller; set at registration and not changeable by the user.

B.2 Book Listing

Field	Data Type	Mandatory	Description
Book Title	String	Yes	Title of the book.
Author	String	Yes	Author of the book.
Price	Numeric	Yes	Positive price with at most two decimal places.
Description	String	No	Description of the book.
Seller	Identifier	Yes	Seller who created the listing; set by the system, not entered by the user.

B.3 Shopping Cart

Field	Data Type	Mandatory	Description
Customer ID	Identifier	Yes	Customer who owns the cart line.
Book ID	Identifier	Yes	Selected book. Unique together with Customer ID.
Quantity	Integer	Yes	Number of copies, from 1 to 10.

B.4 Order

Field	Data Type	Mandatory	Description
Order ID	Identifier	Yes	Unique identifier of the order.
Customer ID	Identifier	Yes	Customer who placed the order.
Order Date	Date/Time	Yes	Date and time the order was placed.
Total Amount	Numeric	Yes	Sum of quantity times unit price over all order items.
Status	String	Yes	Current status; “Placed” when created.

B.5 Order Item

Field	Data Type	Mandatory	Description
Order Item ID	Identifier	Yes	Unique identifier of the order line.
Order ID	Identifier	Yes	Order the line belongs to.
Book ID	Identifier	Yes	Purchased book.
Quantity	Integer	Yes	Number of copies purchased.
Unit Price	Numeric	Yes	Book price copied at purchase time.

C Requirement Traceability Matrix

The matrix maps each requirement to the architecture and design (SAD v1.1 sections), the implementing Django module, the test cases of the Software Test Plan (STP Section 13) and the integration tests (IT-01 to IT-06, STP Section 16.4). Final code references are completed after implementation.

C.1 Requirements to Design and Tests

Req. ID	Description	Architecture / Design	Code module	Test cases	Integration
FR-AUTH-01	User registration	Accounts/Authentication; SAD 3.4, 4.2.1, 4.3	accounts	TC-01, TC-02	–
FR-AUTH-02	User login	Accounts/Authentication; SAD 4.2.1, 4.3	accounts	TC-03, TC-04	IT-06
FR-AUTH-03	User logout	Accounts/Authentication; SAD 4.3	accounts	TC-25	–
FR-BOOK-01	Browse books	Book Management; SAD 3.4, 4.3	books	TC-05	IT-01
FR-BOOK-02	Search books	Book Management; SAD 3.4, 4.3	books	TC-06, TC-07	IT-01
FR-BOOK-03	Seller adds book	Book Management, RBAC; SAD 3.10.3, 4.3	books	TC-08, TC-09	IT-01
FR-CART-01	Add book to cart	Cart Management; SAD 4.2.2, 4.3	cart	TC-10, TC-27	IT-02
FR-CART-02	Remove book from cart	Cart Management; SAD 4.3	cart	TC-11	IT-05
FR-CART-03	View cart	Cart Management; SAD 4.3	cart	TC-26	IT-05
FR-ORDER-01	Place order	Order Management, transaction; SAD 4.2.3, 4.3	orders	TC-12, TC-13	IT-02, IT-03, IT-04, IT-06
FR-ORDER-02	View order history	Order Management; SAD 4.3	orders	TC-14, TC-15	IT-03, IT-05
NFR-01	Search performance	Book Management; SAD 3.8, 4.4	books	TC-16	–
NFR-02	Usability	UX design; SAD 4.5	templates	TC-17	–
NFR-03	Reliability	Order transaction design; SAD 3.6, 4.2.3	orders	TC-18	IT-04

Req. ID	Description	Architecture / Design	Code module	Test cases	Integration
NFR-04	Availability	Deployment and operations; SAD 4.4	–	TC-19	–
NFR-05	Compatibility	Browser UI; SAD 4.5	templates	TC-20	–
NFR-06	Maintainability	Layered modular monolith; SAD 3.5, 4.1	all modules	TC-21	–
NFR-07	Testability	Module boundaries; SAD 4.1	tests	TC-22	–
SEC-01	Role-based access	Security architecture; SAD 3.10.3	accounts	TC-09, TC-23	IT-05
SEC-02	Protection of user data	Security architecture; SAD 3.10.2	all modules	TC-15, TC-24	IT-05

C.2 Security Controls

SEC-CTRL-05, 06 and 07 support SEC-01. SEC-CTRL-01 to 04 and 08 to 20 support SEC-02. Each control is designed in SAD Section 3.10.2 under the same identifier and is verified in STP Section 16.2 under the same identifier. The test cases of SEC-01 and SEC-02 are listed in Appendix C.1.

D Decisions Resolved in Version 1.1 and Remaining Open Items

Decision	Resolution	Where
Role at registration	User chooses Customer or Seller; the server validates it; the user cannot change it afterwards.	FR-AUTH-01, BR-04, SEC-CTRL-07
Seller purchasing	A Seller cannot purchase in this version.	BR-03, RBAC matrix
Database engine	SQLite for development and demonstration; PostgreSQL if hosted.	2.1, 2.4, 3.1.2
Duplicate add-to-cart	Increase the quantity of the existing line; unique (Customer, Book); maximum 10.	FR-CART-01, BR-08
Book ownership	Each listing records its creating Seller; editing and deleting listings are out of scope.	FR-BOOK-03
Logout and view cart	Added as FR-AUTH-03 and FR-CART-03 to match the use-case diagram and routes.	3.2
Security objectives	SO-1 to SO-6 adopted.	3.5.1
Security control IDs	Detailed controls are SEC-CTRL-01 to 20 under SEC-01 and SEC-02.	3.5.4
Login throttling	SEC-CTRL-16 is a recommended, optional enhancement; it is outside the mandatory acceptance baseline.	3.5.4
Order status	“Placed” on creation.	FR-ORDER-01

Decision	Resolution	Where
Payment	Out of scope.	1.2, BR-07

Remaining open item: deployment environment (local demonstration, managed hosting, VPS/cloud VM or containerized deployment). This is an operational choice and does not affect any requirement in this SRS.